

AtlasPay FinTech

SOC 2 Type 1 Readiness - Risk Register

DOCUMENT ID	VERSION	PERIOD
IJZ-ATL-SOC2-RR-20260625	v3.0	FY 2026 Q3 Audit Window
PREPARER	CLASSIFICATION	STATUS
Ijezie Risk Advisory	CONFIDENTIAL	Draft - Pending Review

[LAB-SYNTHETIC]

AtlasPay Risk Register - Detailed View

Document Type: Risk Register (Detailed) **Engagement:** AtlasPay SOC 2 Type 1 Readiness **Date:** 2026-06-26 **Prepared by:** Ijezie Risk Advisory **Document Version:** 1.0 **Status:** Final

Risk Scoring Methodology

AtlasPay uses a 5x5 risk matrix (industry-standard practice commonly attributed to ISO 27005-aligned methodology). Probability and impact are scored 1-5. Risk level is computed as `grid[probability][impact]` lookup. Risk levels: 1=Very Low, 2=Low, 3=Medium, 4=High, 5=Very High.

Treatment options: mitigate (reduce likelihood or impact), accept (within tolerance), transfer (via insurance or contract), avoid (eliminate the activity).

Scoring dimensions:

- **Inherent:** Risk level before any controls are applied (theoretical worst case)
- **Current:** Risk level with current controls in place (today's actual exposure)
- **Residual:** Risk level after planned controls (projected state after POA&M execution)

Risk Register (6 risks)

R-01: Privileged Account Compromise

Description: Compromise of a privileged user account (DBA, root, super-admin) leading to unauthorized access to production systems, customer data, or financial transactions.

Threat source: External attacker (phishing, credential stuffing), malicious insider.

Inherent score: Probability 4 (Very Likely), Impact 5 (Catastrophic) → Level 5 (Very High)

Current score: Probability 2 (Rather Unlikely), Impact 5 (Catastrophic) → Level 3 (Medium)

Residual score: Probability 2 (Rather Unlikely), Impact 5 (Catastrophic) → Level 3 (Medium)

Rationale for residual: Impact cannot be reduced because catastrophic impact is inherent to privileged access compromise. Probability is reduced via MFA enforcement, RBAC, just-in-time access, and session recording (planned). Floor is Medium because no control eliminates human-error vulnerability.

Treatment: mitigate

Linked controls: ACC-01, CC6.1, CC6.2, CC6.3

Linked POA&M: POA&M-01, POA&M-02

R-02: Payment Data Exfiltration via API

Description: Unauthorized extraction of payment data (PAN, CVV, transaction history) through compromised API endpoints or insider abuse of API access.

Threat source: External attacker (API exploit), malicious insider with API access.

Inherent score: Probability 4 (Very Likely), Impact 5 (Catastrophic) → Level 5 (Very High)

Current score: Probability 2 (Rather Unlikely), Impact 5 (Catastrophic) → Level 3 (Medium)

Residual score: Probability 2 (Rather Unlikely), Impact 5 (Catastrophic) → Level 3 (Medium)

Rationale for residual: PCI scope requires encryption + tokenization, reducing exfiltration value. API rate limiting + anomaly detection (planned via POA&M-09) reduces probability. Impact remains catastrophic because any payment data exposure has regulatory consequences.

Treatment: mitigate

Linked controls: ACC-01, CC6.6, CC6.7, CC8.1

Linked POA&M: POA&M-09

R-03: Ransomware on Production Database Host

Description: Ransomware infection on production database host encrypting customer data and demanding payment for decryption, with potential data exfiltration (double extortion).

Threat source: External attacker (phishing, exploit), insider with database access.

Inherent score: Probability 3 (Likely), Impact 5 (Catastrophic) → Level 4 (High)

Current score: Probability 3 (Likely), Impact 3 (Serious) → Level 3 (Medium)

Residual score: Probability 3 (Likely), Impact 3 (Serious) → Level 3 (Medium)

Rationale for residual: EDR + immutable backups reduce impact (recovery without payment). Probability remains because ransomware actors target FinTech specifically. Tabletop exercises (POA&M-10) validate response readiness.

Treatment: mitigate

Linked controls: CC7.4, CC7.5, A1.3

Linked POA&M: POA&M-10, POA&M-11

R-04: Third-Party SaaS Breach (Vendor Compromise)

Description: Security breach at a critical third-party SaaS vendor (Cloud, Payment Gateway, Identity Provider) that AtlasPay depends on, leading to data exposure or service disruption.

Threat source: External attacker targeting vendor, vendor insider.

Inherent score: Probability 4 (Very Likely), Impact 4 (Critical) → Level 4 (High)

Current score: Probability 3 (Likely), Impact 4 (Critical) → Level 4 (High)

Residual score: Probability 3 (Likely), Impact 4 (Critical) → Level 4 (High)

Rationale for residual: AtlasPay cannot eliminate third-party breach risk. SOC 2 Type 2 vendor reports, continuous security rating monitoring, contractual breach notification SLAs, and incident response coordination reduce probability and impact slightly but cannot drive residual below current state. This is the realistic ceiling - **honest-call discipline requires keeping residual High** rather than artificially reducing it.

Treatment: mitigate

Linked controls: TPRM-01, CC9.2, CC3.3, CC3.4

Linked POA&M: POA&M-03, POA&M-04, POA&M-05

Board narrative: "AtlasPay depends on 7 critical SaaS vendors. Vendor compromise is the single highest residual risk because it cannot be fully controlled by AtlasPay - only managed through vendor due diligence, contractual protections, and incident coordination. The residual High rating reflects this structural reality, not a control failure."

R-05: Insider Threat (Malicious Employee)

Description: A current employee or contractor with authorized access intentionally misuses access for fraud, data theft, or sabotage.

Threat source: Insider (employee, contractor with malicious intent).

Inherent score: Probability 4 (Very Likely), Impact 4 (Critical) → Level 4 (High)

Current score: Probability 3 (Likely), Impact 4 (Critical) → Level 4 (High)

Residual score: Probability 2 (Rather Unlikely), Impact 4 (Critical) → Level 3 (Medium)

Rationale for residual: Background checks, quarterly access reviews, separation of duties, and monitoring reduce probability. Impact remains critical because any insider with privileged access can cause significant harm. Medium is the realistic floor - humans are inherently unpredictable.

Treatment: mitigate

Linked controls: ACC-01, SA-01, CC6.3

Linked POA&M: POA&M-06, POA&M-07

R-06: Insufficient Audit Logging

Description: Inadequate audit logging of security-relevant events (auth, access, admin actions) leading to inability to detect, investigate, or recover from incidents.

Threat source: Configuration error, vendor logging failure.

Inherent score: Probability 5 (Almost Certain), Impact 2 (Significant) → Level 4 (High)

Current score: Probability 2 (Rather Unlikely), Impact 2 (Significant) → Level 2 (Low)

Residual score: Probability 2 (Rather Unlikely), Impact 2 (Significant) → Level 2 (Low)

Rationale for residual: Audit log forwarder to Datadog with retention + alerting (operational since Phase 1) significantly reduced probability. Impact remains significant because loss of audit trail during an incident impairs response. New dependency: Datadog availability - documented as separate risk in BCP.

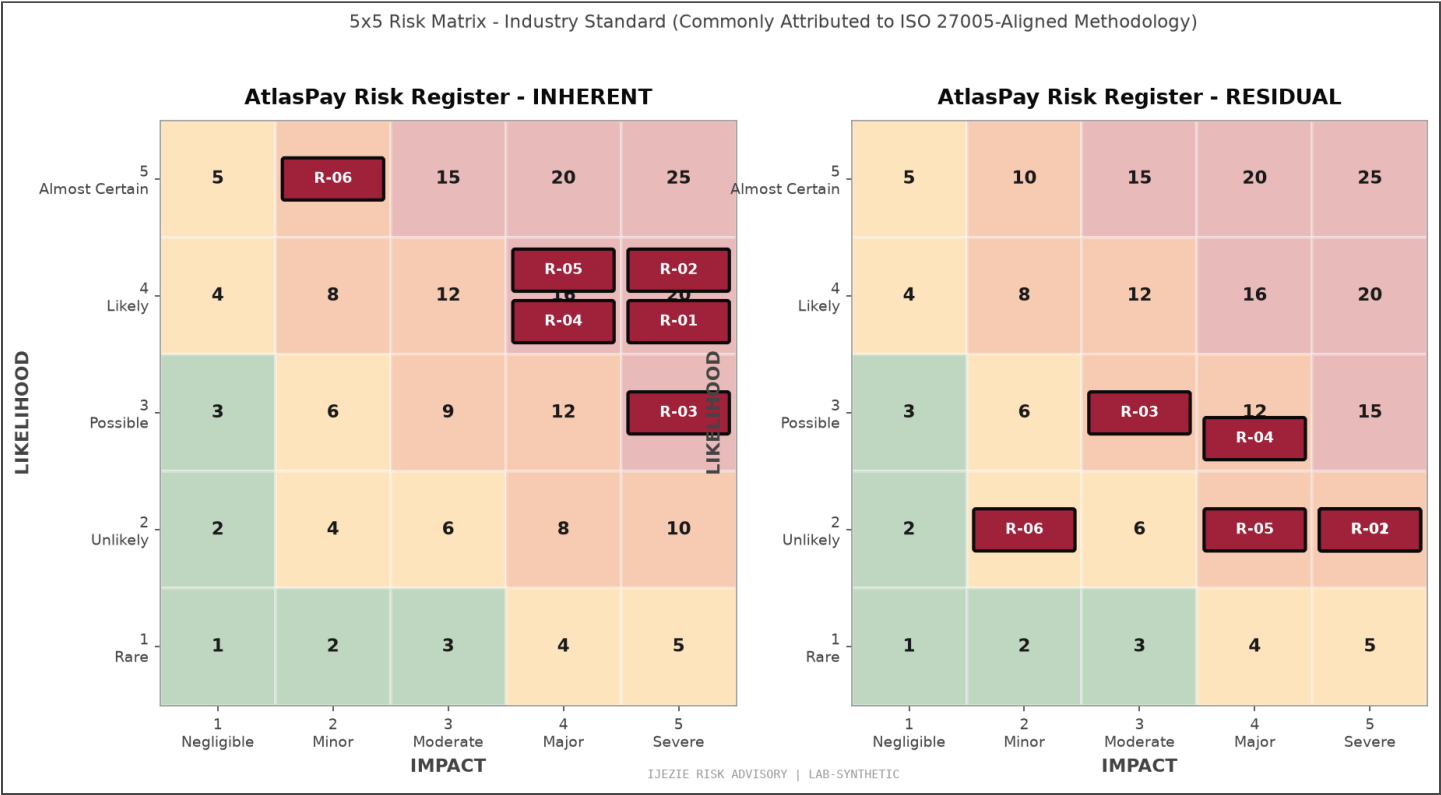
Treatment: mitigate

Linked controls: CC7.1, CC7.2, CC7.3

Linked POA&M: POA&M-08, POA&M-12

Risk Heatmap

The 5x5 risk matrix below shows where each AtlasPay risk plots on a likelihood vs impact grid. INHERENT (left) represents pre-control exposure; RESIDUAL (right) shows post-control position after POA&M execution.



Risk Distribution

LEVEL	INHERENT	CURRENT	RESIDUAL
Very High (5)	2	0	0
High (4)	4	2	1

LEVEL	INHERENT	CURRENT	RESIDUAL
Medium (3)	0	4	4
Low (2)	0	0	1
Very Low (1)	0	0	0

Honest-call summary: 4 risks reduced from High to Medium through controls. 2 risks (R-03, R-04) plateau at Medium/High because impact cannot be eliminated. R-04 retains High per honest-call discipline.

[LAB-SYNTHETIC] This risk register is a portfolio demonstration artifact. AtlasPay is a fictional FinTech persona; all risk data is illustrative. For real client engagements, scoring reflects actual assessments, evidence sampling, and stakeholder interviews.

Ijezie Risk Advisory - Solo vCISO consulting, NIST-first methodology, SOC 2 / ISO 27001 / HIPAA / FFIEC.